

Summary Post

by Séba Daher - Tuesday, 16 June 2026, 6:21 AM

(Evidence: <https://www.my-course.co.uk/mod/forum/discuss.php?d=371468#p749750>)

The discussion examined the criticisms of CVSS raised by Wunder et al. (2024) and the case for replacing it. The initial argument held that CVSS conflates technical severity with risk and rests on a formula that is neither empirically nor theoretically justified (Spring et al., 2018), making the Stakeholder-Specific Vulnerability Categorization (SSVC), a decision-oriented alternative, the stronger basis for prioritisation (Spring et al., 2020).

Peer contributions refined rather than overturned this position. One response advanced the Exploit Prediction Scoring System as an alternative focused on likelihood, while another argued for combining CVSS with exploit data, organisational context and peer review within a governed triage process. These exchanges clarified a central point: likelihood and severity are each single dimensions, and substituting one for the other repeats the original weakness. Risk depends on both consequence and uncertainty (Aven and Thekdi, 2025), so no individual score can carry a prioritisation decision alone. EPSS adds a reproducible likelihood signal (Jacobs et al., 2021), yet consistency concerns persist wherever ordinal categories rely on human interpretation (Cox, 2008).

The wider unit material reinforced this conclusion. Attack trees and Monte Carlo simulation offer structured ways to model exploitation likelihood, disaster recovery and availability analysis address the consequence dimension that scoring systems overlook, and multi-criteria decision analysis provides a principled method for weighting competing factors. Together they frame effective vulnerability prioritisation as a multi-criteria decision problem rather than a single-number ranking.

The revised position is therefore that CVSS and EPSS are complementary signals, best combined with asset context inside a transparent decision framework such as SSVC. The remaining challenge is how to weight those inputs defensibly, and how to ensure that quantitative outputs are not undermined by weak or subjective inputs.

References

Aven, T. and Thekdi, S. (2025) Risk Science: An Introduction. 2nd edn. Oxon: Routledge.

Cox, L.A. (2008) 'What's wrong with risk matrices?', Risk Analysis, 28(2), pp. 497-512. doi:10.1111/j.1539-6924.2008.01030.x.

Jacobs, J., Romanosky, S., Edwards, B., Roytman, M. and Adjerid, I. (2021) 'Exploit prediction scoring system (EPSS)', Digital Threats: Research and Practice, 2(3), article 20. doi:10.1145/3436242.

Spring, J., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2018) Towards Improving CVSS. Pittsburgh, PA: Software Engineering Institute, Carnegie Mellon University. Available at: https://www.sei.cmu.edu/documents/574/2018_019_001_538372.pdf (Accessed: 1 June 2026).

Spring, J., Hatleback, E., Householder, A., Manion, A. and Shick, D. (2020) 'Prioritizing vulnerability response: a stakeholder-specific vulnerability categorization (version 1.1)', Workshop on the Economics of Information Security. Brussels, Belgium, December.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: a user-centric study on evaluating widespread security vulnerabilities', 2024 IEEE Symposium on Security and Privacy (SP), pp. 1102-1121. doi:10.1109/SP54263.2024.00058.